

Title Page

Student name: Omotayo Akinola

Student ID: 2025/GCR/12813

Course: Compliance Frameworks and Legal Requirements

Instructor: Dr Aminu Idris

Date: 7th of May, 2026

Executive Summary

This report presents a comparative analysis of two significant cybersecurity incidents that occurred between 2023 and 2024: the cyberattack on Globacom Limited, Nigeria's second-largest telecommunications operator, and the data breach suffered by Finastra, one of the world's largest financial technology companies headquartered in London, United Kingdom. Both incidents are examined across nine analytical dimensions including organizational profile, incident type, applicable regulations, root causes, detection and disclosure timelines, regulatory response, impact assessment, lessons learned, and individual accountability considerations.

The Globacom incident, which began on July 13, 2023, involved a DNS hijack attack that locked the company's approximately 60 million subscribers' service provider out of all internal systems for months, accompanied by a \$2.5 million ransom demand. The attack went undetected internally. It was the Nigerian Communications Commission, not Globacom, that discovered and reported the breach to the company. Globacom never publicly disclosed the incident to subscribers or regulators, in direct violation of the Nigeria Data Protection Act 2023's mandatory 72-hour notification requirement. The breach remained publicly unknown for over a year until investigative reporting by TechCabal exposed it in October 2024. Root cause analysis identified a DNS infrastructure compromise enabled by inadequate security controls, compounded by a decade of underinvestment and a highly centralized founder-led governance structure that left the company institutionally incapable of mounting an effective response.

The Finastra breach, unfolded between October 31 and November 8, 2024, involved unauthorized access to the company's Secure File Transfer Platform through compromised credentials, resulting in the exfiltration of approximately 400 gigabytes of sensitive data, including Social Security numbers and financial account details belonging to over 888,000 individuals across the United States. Unlike Globacom, Finastra's internal Security Operations Centre detected the breach on November 7, 2024, and notified business clients within 24 hours. However, individual consumer notifications were significantly delayed, with some notification letters not mailed until July 2025, a timeline that likely constitutes violations of UK GDPR and multiple US state breach notification laws. The incident triggered multiple class action investigations by US law firms and ongoing regulatory scrutiny from the UK Financial Conduct Authority.

Comparative analysis of both incidents reveals three systemic findings. First, organizational culture and governance structure are the primary determinants of incident response quality. Globacom's centralized, opaque governance produced concealment, while Finastra's institutional structure produced rapid technical containment but failed on consumer transparency. Second, regulatory maturity directly shapes organizational behaviour. Finastra operated under one of the world's most developed cybersecurity frameworks and responded with relative transparency, while Globacom operated under a newly enacted regulatory framework with limited enforcement capacity, creating minimal institutional incentive for disclosure. Third, both incidents share identical technical root

causes. One is inadequate access controls, absence of multi-factor authentication, insufficient monitoring, and a failure to treat cybersecurity as a board-level governance priority. This demonstrates that the gap between a Nigerian telecommunications company and a global British fintech is narrower than their regulatory environments suggest when it comes to fundamental security hygiene.

Based on the findings of this analysis, the following priority recommendations are directed at both organizations and the broader industry. In the immediate term, multi-factor authentication must be enforced on all critical platforms without exception, formal incident response plans must be rehearsed rather than merely documented, and mandatory breach notification timelines must be treated as legal obligations. In the medium term, investment in Security Operations Centre capability, Data Loss Prevention tooling, and qualified Data Protection Officers addresses the monitoring and compliance gaps that both incidents exposed. In the long term, cybersecurity must be elevated to board-level governance, supported by independent board structures, dedicated cybersecurity committees, and international certification frameworks such as ISO/IEC 27001. The evidence from both incidents makes clear that cybersecurity failure is, at its core, a leadership and governance failure and that no technical solution substitutes for institutional accountability at the highest level of an organization.

Detailed analysis for Incident A - Globacom Limited

Organization Profile of Globacom Limited

Globacom Limited, commonly known as Glo, is a Nigerian multinational telecommunications company founded in 2003 by billionaire businessman Mike Adenuga. Headquartered at Mike Adenuga Tower, Victoria Island, Lagos, Globacom operates as Nigeria's second-largest telecom operator, offering mobile voice and data services, broadband, international gateway services, and submarine cable connectivity through its Glo-1 cable linking the United Kingdom to Nigeria. As of early 2023, the company reported over 60.7 million subscribers and an estimated annual revenue of \$1.5 billion, with a workforce of between 1,000 and 5,000 employees. Beyond Nigeria, Globacom has an operational presence in Ghana and the Republic of Benin.

Globacom Incident

On the night of July 13, 2023, Globacom staff could not access their emails or use work applications, marking the beginning of a major cyberattack. Based on investigative reporting by TechCabal, conversations with over 30 people revealed that hackers likely gained access to Globacom's Domain Name System (DNS) in mid-2023, a type of attack that redirects traffic from legitimate websites to malicious ones. The attack resulted in a ransom demand of \$2.5 million, classifying this incident as a ransomware-linked DNS hijack, one of the most significant cybersecurity breaches to hit Africa in recent years

The security requirements and regulations relevant to that Globacom

Regulation	What It Required of Globacom	Key Breach	Penalty
NDPA 2023	Protect subscriber data; report breach to NCC within 72 hours	Globacom did not self-report	Up to 2% gross revenue or ₦10 million
NCC Consumer Code	Maintain service quality; protect customer data	Customer calls dropped; services failed	Fines, licence sanctions
Cybercrime Act 2015	Report cyberattacks; protect critical infrastructure	Delayed and inadequate reporting	Criminal prosecution possible

The root causes and control failures that enabled the incident (technical, process, and human factors)

Technical failure: The attack method suggested a DNS hijack, and intermittent outages in the weeks before July 13 were not routine glitches, they were tested by the attackers probing the system

- **Process failure:** Telecom executives and analysts highlight a decade of underinvestment and weak corporate governance as critical factors behind Globacom's vulnerability
- **Human/Governance failure:** The company is run like a one-man business, with everything running up to Mike Adenuga, and no decision taken without his approval, a structure that slowed incident response significantly

The detection and disclosure timeline

Date	What Happened
Late June 2023	Intermittent outages begin — staff assume routine glitches
July 13, 2023	Full cyberattack hits — emails and all systems locked
July–August 2023	Staff switch to WhatsApp; customers cannot reach service teams
2023–2024	Globacom never self-reports the breach
Early 2024	Staff still using WhatsApp for internal communication
October 2024	TechCabal publishes full investigative report
October 2024	NCC and NITDA both confirm the attack but do not share specifics

Globacom didn't report the breach, the NCC, through its Cybersecurity Emergency Response Teams (CERT), had monitored the impending attack and brought it up with the company. This is a direct violation of the 72-hour notification rule

Organizational & Regulatory Response

One month after the attack was reported publicly, Globacom named a new CEO and board of directors in October 2024 after pressure from the NCC, the first time since 2003 that someone outside Mike Adenuga's family would control the company. However, Ahmad Farroukh, appointed CEO in October 2024, stepped down after just one month, reportedly due to challenges aligning with Globacom's centralised operational structure heavily influenced by founder Mike Adenuga.

On the regulatory side, the NCC released sweeping new corporate governance rules in August 2025, giving Globacom 24 months to appoint a CEO separate from the Chairman or face sanctions including fines and possible licence revocation

Impact Assessment

Area	Impact
Operational	Staff locked out of all systems for months; WhatsApp used as substitute
Customer	Calls dropped; service teams unreachable; enterprise partners affected
Financial	\$2.5M ransom demand; ongoing regulatory fines
Reputational	Globacom's market share dropped to 13% with just 19.1 million active subscribers.
Regulatory	Fined for NIN non-compliance; threatened with disconnection by MTN over unpaid interconnection debts

Lessons Learned & Remediation Roadmap

Timeline	Action
Short-term (0–3 months)	Implement proper DNS security; restore encrypted email systems; establish incident response team
Medium-term (3–12 months)	Train staff on cybersecurity; set up 24/7 monitoring; create a formal breach reporting process
Long-term (12+ months)	Separate CEO and Chairman roles; invest in infrastructure; build a proper cybersecurity governance framework

Individual accountability and criminal exposure considerations, including the role of whistleblowers and protections where relevant

The Globacom incident raises serious questions about individual accountability. The company's centralized structure, where Mike Adenuga as founder, chairman, and effective CEO made all

decisions, this meant that responsibility for the security failures ultimately rested at the very top of the organisation. The Nigerian Cybercrime Act 2015 allows for prosecution of individuals, not just organisations, in cybersecurity failures involving critical infrastructure. Notably, TechCabal's investigation was only possible because over 30 employees and insiders spoke anonymously, effectively acting as informal whistleblowers. Nigeria currently has no dedicated whistleblower protection law for private sector employees, meaning those sources took personal risks to expose this incident

Detailed analysis for Incident B - Finastra

Organization Profile

Finastra is a British financial technology company headquartered in London, United Kingdom, formed in 2017 through the merger of Misys and D+H under the ownership of private equity firm Vista Equity Partners. As one of the world's largest fintech companies, Finastra provides mission-critical software for retail banking, transaction banking, lending, and treasury and capital markets. The company serves over 8,000 financial institutions across 130 countries, including 45 of the world's top 50 banks, among them are JPMorgan Chase, HSBC, and Bank of America. With annual revenues of approximately \$1.9 billion USD and a workforce of over 7,000 employees, Finastra's systems facilitate roughly \$7 trillion in daily financial transactions and underpin \$3.8 trillion in syndicated loans globally. Its scale means that any compromise of its systems carries systemic risk for the entire global banking infrastructure

Incident

On November 7, 2024, Finastra's Security Operations Centre detected suspicious activity related to an internally hosted Secure File Transfer Platform used to send files to certain customers, and the company immediately launched an investigation alongside a third-party cybersecurity firm. The incident is classified as a credential-based unauthorized access and data exfiltration attack. Initial evidence pointed to credentials that were compromised as the root cause of the breach. Notably, this was not a ransomware attack, no malware was deployed to the Finastra network, and there was no direct impact on Finastra's customer operations or systems. The attacker used IBM Aspera, a legitimate high-speed file transfer tool, to exfiltrate data, a technique known as "living off the land" that bypasses traditional security detection. The breach is believed to be linked to a cybercriminal known as "abyss0" on BreachForums, who claimed to have stolen and attempted to sell 400GB of Finastra's data.

The security requirements and regulations relevant to that organization

Regulation	Jurisdiction	Why It Applies	Key Obligation Triggered
GDPR 2018	EU / UK	Finastra processes personal data of EU and UK citizens	72-hour breach notification to ICO; data subject rights
UK GDPR / DPA 2018	UK	UK-headquartered company post-Brexit	Report to ICO within 72 hours of awareness
GLBA (Gramm-Leach-Bliley)	USA	Handles financial data of US	Safeguards Rule — protect customer

Act)		consumers	financial information
PCI-DSS	Global	Processes payment and financial account data	Secure handling of cardholder and account data
FCA regulations	UK	Regulated by Financial Conduct Authority as a critical financial infrastructure provider	Operational resilience, incident reporting obligations
US State Breach Notification Laws	USA	Over 888,000 US individuals affected	Mandatory notification to 9 state Attorneys General

The root causes and control failures that enabled the incident

Technical failure: The data breach also revealed inadequate access controls for SFTP-stored data, a single set of compromised credentials provided access to directories containing data for multiple clients, leading to increased risk.

Process failure: Finastra's security measures failed due to weaknesses in monitoring and detecting unauthorized access to its SFTP, and the lack of advanced threat detection systems and delayed recognition of anomalous activities allowed the attacker to exfiltrate data over a prolonged period.

Human factor: The root cause was compromised credentials, meaning either phishing, password reuse, or insider misuse enabled the attacker's initial access. No MFA or sufficiently strong authentication was protecting the SFTP platform.

Historical pattern: In March 2020, Finastra suffered another major cybersecurity incident when it was hit by ransomware actors, and reports from threat monitoring platforms highlighted the firm's lackluster vulnerability management strategy. This 2024 breach therefore represents a repeated failure to address systemic security weaknesses.

Detection & Disclosure Timeline

Date	What Happened
Oct 31, 2024	Attacker first gains access to SFTP and begins exfiltrating data
Oct 31 – Nov 8	Attacker accesses platform at multiple intervals over 8 days
Nov 7, 2024	Finastra's SOC noticed unusual activity on their SFTP system
Nov 8, 2024	Finastra first communicated the incident to customers within 24 hours

	of detection
Nov 8, 2024	"abyss0" posts 400GB data for sale on BreachForums dark web forum
Nov 2024	KrebsOnSecurity breaks the story publicly
Feb 12, 2025	Finastra began reaching out to affected individuals, over 3 months after discovery
Feb 16, 2025	Official data breach notice filed with Massachusetts OCABR
Jul 3, 2025	Finastra began mailing notification letters to affected individuals, nearly 8 months after the breach
Jul 2025	Multiple US law firms launch class action investigations

Finastra detected the breach quickly and notified business customers within 24 hours, this is commendable. However, individual consumer notifications took 7–8 months, which likely triggered GDPR and US state law violations on notification timelines.

Organizational & Regulatory Response

Upon detection, Finastra immediately launched an investigation and engaged leading cybersecurity firms, notified law enforcement, and continued to support their investigation. The company isolated and contained the compromised SFTP platform within hours of detection. After discovering the breach, Finastra reported the incident to law enforcement including the FBI, and engaged top cybersecurity firms. Breach disclosures were filed with nine US State Attorneys General. Finastra offered a complimentary 24-month membership to Experian IdentityWorks to impacted individuals, providing identity protection and identity theft resolution services.

On the litigation front, Federman & Sherwood, a leading law firm with extensive experience in data privacy litigation, launched an investigation into the breach in July 2025. Multiple additional class action investigations were filed by US law firms through mid-2025. No formal GDPR fine from the UK ICO or FCA enforcement action has been publicly confirmed as of the time of writing, though regulatory scrutiny has been noted across multiple sources

Impact assessment

Dimension	Impact
Data exposure	400GB claimed stolen; 888,627 Americans confirmed affected, with exposed data including names, addresses, dates of birth, Social Security numbers, and financial account information

Financial	Cost of cybersecurity firms, FBI investigation support, 24-month Experian coverage for 888K people, legal fees, multiple class action exposures
Reputational	The reputation was severe. A company whose entire value proposition is securing global banking infrastructure was itself breached. Client trust in Finastra's security is fundamentally undermined
Operational	SFTP platform taken offline; file transfer operations disrupted for affected clients
Systemic risk	Given Finastra serves 45 of the top 50 global banks, the breach created downstream anxiety across the entire global banking system about the security of shared fintech infrastructure

Lessons Learned & Remediation Roadmap

Phase	Action	Owner	Priority
0–3 months	Enforce MFA on all SFTP and file transfer platforms	CISO / IT Security	Critical
0–3 months	Implement privileged access management, one credential should not access multiple client directories	IT Architecture	Critical
0–3 months	Accelerate individual consumer notifications to meet 72-hour GDPR requirement	Legal / DPO	Critical
3–12 months	Deploy data loss prevention (DLP) tools to detect and block abnormal bulk data transfers	SOC / IT Security	High
3–12 months	Replace legacy SFTP with Managed File Transfer (MFT) solution with full audit logging	IT Operations	High
3–12 months	Conduct comprehensive third-party security audit across all platforms	External firm / Board	High
12+ months	Implement a vendor and supply chain risk	CISO / Procurement	Medium

	management programme		
12+ months	Pursue ISO 27001 recertification and SOC 2 Type II compliance	CISO / Compliance	Medium

Individual accountability and criminal exposure considerations, including the role of whistleblowers and protections where relevant

The Finastra breach raises important questions about individual accountability at the executive level. As a UK-headquartered company, the FCA's Senior Managers and Certification Regime (SMCR) places direct personal liability on named senior managers for cybersecurity and operational resilience failures. Under SMCR, the Chief Information Security Officer and Chief Technology Officer could face personal regulatory sanctions if it is determined that reasonable steps were not taken to prevent the breach, particularly given the company's prior 2020 ransomware incident showing a pattern of security gaps.

Regarding whistleblowers, the UK's Public Interest Disclosure Act 1998 and the EU Whistleblower Protection Directive provide protections for employees who report cybersecurity failures internally or to regulators. No public whistleblower disclosures have been made in this case. The attacker "abyss0" deleting their BreachForums post shortly after listing the data raises unresolved questions, including whether Finastra negotiated with the attacker to suppress the data, which if true would carry its own legal and ethical implications under UK and US law.

Comparative Analysis

Overview

The Globacom cyberattack of 2023 and the Finastra data breach of 2024 represent two of the most instructive cybersecurity incidents in their respective regions within the past three years. While both organizations operate at significant scale within critical sectors of the global economy, the nature of their incidents, their regulatory environments, and their responses, differ in ways that reveal the gap between emerging and mature cybersecurity governance frameworks. Taken together, these two incidents offer a comprehensive lens through which to examine how organizational culture, regulatory pressure, and technical preparedness shape outcomes when a breach occurs.

Attack Type & Technical Comparison

The two incidents differ fundamentally in their technical character. The Globacom attack was a DNS hijack: a sophisticated infrastructure-level assault that redirected the company's network traffic and locked staff out of all internal systems for months. It carried a \$2.5 million ransom demand and caused visible, prolonged operational paralysis. The Finastra breach, by contrast, was quieter and more targeted: a credential-based intrusion into a single file transfer platform that enabled the silent exfiltration of 400 gigabytes of sensitive financial data over eight days without triggering any alarms until the final day.

This distinction is important. Globacom suffered a loud, disruptive attack that was impossible to hide internally. Finastra suffered a silent, precise attack designed to extract maximum value without detection. In some respects the Finastra breach is the more dangerous of the two, precisely because its subtlety meant that 400GB of data containing Social Security numbers and financial account details was stolen before anyone noticed. Both attack types, however, share a common root: inadequate monitoring, weak access controls, and a failure to apply security fundamentals.

Detection & Disclosure

Finastra's Security Operations Centre detected suspicious activity on November 7, 2024, just one day before the attacker's exfiltration window closed and notified business customers within 24 hours. This demonstrates a functioning internal security capability. Globacom, by contrast, had no such capability. The NCC's own Cybersecurity Emergency Response Team detected the impending attack and had to approach Globacom directly. Not only did Globacom fail to detect the breach internally, it never self-reported it, even after becoming aware. The breach remained publicly unknown for over a year, until TechCabal published its investigative report in October 2024.

This contrast reflects something deeper than technical readiness. Finastra's rapid internal detection reflects years of investment in a security operations function. Globacom's failure reflects a governance culture where cybersecurity was not treated as a board-level priority. However, Finastra is not without its own disclosure failures. While business customers were notified promptly, individual consumer notifications were delayed by seven to eight months, with

some notification letters only mailed in July 2025, a timeline that almost certainly violates GDPR's 72-hour notification requirement and US state breach notification laws. Both companies therefore failed their end consumers on disclosure, though the nature and severity of those failures differ significantly.

Regulatory Environment Comparison

The two incidents played out in dramatically different regulatory landscapes, and that difference shaped everything from the speed of the response to the consequences that followed.

Finastra operated under one of the world's most developed cybersecurity and data protection frameworks. UK GDPR and the Data Protection Act 2018 impose strict breach notification obligations, significant financial penalties, and direct accountability on named senior managers through the FCA's Senior Managers and Certification Regime. The existence of these frameworks meant that Finastra faced immediate legal obligations the moment it detected the breach, creating a strong institutional incentive to respond quickly and transparently.

Globacom, by contrast, operated under the Nigeria Data Protection Act 2023, Nigeria's regulatory infrastructure, while improving, lacked the enforcement maturity and institutional capacity of its UK counterpart. The NCC and NDPC confirmed the attack but did not publish specific findings or impose confirmed financial penalties. This regulatory immaturity partly explains, though does not excuse Globacom's silence. Where the regulatory environment is weak, the incentive to disclose and remediate is correspondingly weaker.

This comparison highlights a critical reality in global cybersecurity governance: regulatory frameworks do not just punish failures after the fact, they actively shape organizational behaviour before and during an incident. Mature regulation creates a culture of compliance; immature regulation creates a culture of concealment.

Organizational Response & Governance

Finastra's response, while imperfect on consumer notification timelines, demonstrated institutional competence. The SFTP platform was isolated within hours, third-party cybersecurity firms were engaged immediately, the FBI was notified, and affected business clients received direct communication within 24 hours. This is the response profile of an organization with practiced incident response procedures.

Globacom's response was the opposite. Internal communications collapsed to WhatsApp. Customer calls were dropped. Enterprise partners could not reach their account managers. No public statement was ever made. A new CEO was only appointed seven months after the breach became public and under direct NCC pressure, not voluntary action. That CEO resigned after one month. The company's governance structure in which the founder exercised total control over all decisions. This meant that the institutional capacity to respond effectively simply did not exist.

What both incidents share, however, is a governance gap at the board level. In Globacom's case it was explicit, no separation of CEO and Chairman, no independent board, no cybersecurity committee. In Finastra's case it was subtler, a Board that approved security budgets but apparently did not ensure that legacy platforms like the SFTP system were subject to the same security rigour as core systems. The lesson in both cases is identical: cybersecurity is a board-level governance responsibility, not an IT department task.

Impact Comparison

In terms of confirmed quantifiable impact, Finastra's breach was larger. 888,627 confirmed affected individuals, 400GB of stolen data including Social Security numbers, and multiple active class action proceedings. Globacom's confirmed data exposure remains unquantified, as the company never disclosed what customer data was accessed or compromised.

However, in terms of operational and reputational damage, Globacom suffered more severely. The complete collapse of internal communications for months, the loss of 40 million subscribers in subsequent regulatory audits, a market share decline from approximately 29% to 12%, and the public narrative of a company in terminal decline all point to an organization whose breach was the tipping point of a broader institutional crisis. Finastra, despite the severity of its data exposure, continued operating normally and has not experienced comparable market share loss.

Recommendations & Prioritized Remediation Roadmap

The following recommendations are derived from cross-incident analysis of the Globacom cyberattack of 2023 and the Finastra data breach of 2024. They are organized across three time-bound phases and mapped to responsible owners. Recommendations marked as applying to both incidents represent systemic lessons for any organization operating critical digital infrastructure, regardless of geography or sector.

Phase 1: Immediate: Contain, Detect, Disclose

Recommendation	Incident	Owner	Priority
Enforce multi-factor authentication on all critical platforms Finastra's breach was enabled by a single set of compromised credentials with no MFA. Globacom's DNS systems lacked adequate authentication controls. MFA is the single highest-ROI security control available and should be non-negotiable on any platform handling sensitive data.	Both	CISO	Critical
Establish a 24/7 Security Operations Centre with SIEM Globacom had no internal detection capability, the NCC found the breach before they did. Finastra's SOC detected the breach but only on day 8 of active exfiltration. A properly resourced SOC with	Both	CISO	Critical

Security Information and Event Management tooling would have caught both incidents earlier.			
Implement and rehearse a formal Incident Response Plan Globacom had no incident response plan as staff defaulted to WhatsApp. Finastra responded well technically but failed on consumer notification timelines. A documented, rehearsed IRP with defined roles, escalation paths, and regulatory notification checklists prevents both failures simultaneously.	Both	CISO	Critical
Comply with 72-hour breach notification requirements Both organizations failed on consumer notification timelines. Globacom never notified subscribers at all, and Finastra took 7–8 months to notify affected individuals. Under NDPA 2023, UK GDPR, and US state laws, failure to notify within 72 hours is a direct regulatory violation carrying significant financial penalties.	Both	CEO/ DPO / Legal	Critical
Implement DNSSEC and DNS traffic monitoring The Globacom attack exploited DNS infrastructure that lacked basic security hardening. DNSSEC prevents DNS hijacking by cryptographically signing DNS records. DNS monitoring provides early warning of anomalous traffic patterns, the two-week reconnaissance phase would have been caught.	Globacom	IT Infrastructure	Critical
Apply least-privilege access controls to all file transfer platforms. In the Finastra breach, one compromised credential provided access to multiple client directories. A least-privilege model, where each credential can only access the minimum data required, would have limited the blast radius of the breach	Finastra	IT Security / Architecture	Critical

dramatically, potentially reducing 400GB of exposure to a fraction of that.			
---	--	--	--

Phase 2: Medium-term — Strengthen controls & culture

Recommendation	Incident	Owner	Priority
Deploy Data Loss Prevention tools Neither organization had DLP controls capable of detecting or blocking abnormal bulk data transfers. Finastra's attacker used IBM Aspera, a legitimate tool, to exfiltrate 400GB undetected. DLP systems flag and block unusually large outbound transfers regardless of the tool used, directly addressing this attack vector.	Both	CISO / DPO	High
Mandate company-wide cybersecurity awareness training Globacom staff treated two weeks of pre-attack reconnaissance signals as routine glitches. Finastra's breach likely began with compromised credentials obtained through phishing or password reuse, both preventable through staff training. Annual training is insufficient; quarterly micro-training with simulated phishing is the current standard.	Both	CISO/HR	High
Appoint a qualified Data Protection Officer Both organizations are required under their applicable data protection laws to appoint a DPO, NDPA 2023 for Globacom, UK GDPR for Finastra. A DPO provides dedicated ownership of breach notification obligations, data subject rights, and regulatory liaison, precisely the functions that failed in both incidents.	Both	Board	High
Replace legacy SFTP with Managed File Transfer solution Finastra's breach exploited a legacy SFTP platform with inadequate logging, monitoring, and access controls. Modern MFT solutions provide end-to-end encryption, granular access controls, full audit trails,	Finastra	CISO/IT Operations	High

and real-time anomaly alerts, all of which were absent and all of which would have limited the breach			
Invest in network infrastructure and reduce technical debt Globacom's decade of underinvestment in infrastructure left it technically vulnerable and unable to recover quickly.	Globacom	Board and Executive	High

Phase 3: Long-term — Governance transformation & resilience

Recommendation	Incident	Owner	Priority
Elevate cybersecurity to board-level governance. Both incidents ultimately reflect boards that did not treat cybersecurity as a strategic priority. Best practice requires a dedicated Board Cybersecurity Committee, a CISO with direct board access, regular security briefings at board level, and cybersecurity KPIs included in executive performance reviews. Security cannot remain an IT department concern.	Both	Board	Medium
Implement a third-party and supply chain risk management programme Finastra is itself a third-party provider to 8,000 banks, making its breach a systemic supply chain risk event. Both organizations must assess the security posture of their vendors, partners, and technology providers through regular audits, contractual security obligations, and continuous monitoring. The weakest link in any supply chain defines the overall security level.	Both	CISO / Procurement	Medium
Pursue ISO/IEC 27001 certification and regular independent audits Neither organization had demonstrated adherence to international information security standards at the time of their respective breaches. ISO 27001 certification provides a systematic, continuously improving framework for	Both	CISO / External auditor	Medium

security management and signals to regulators, clients, and partners that security is taken seriously at an institutional level.			
Separate CEO and Chairman roles and establish independent board Globacom's founder-led governance model, where one individual controlled all decisions, was directly cited by industry experts and regulators as a root enabler of both the breach and the inadequate response. The NCC has mandated this separation by 2027. Independent boards with genuine oversight authority are a prerequisite for institutional resilience.	Globacom	Board	Medium
Establish confidential whistleblower and ethics reporting channels The Globacom breach was ultimately exposed by over 30 anonymous insiders speaking to journalists, not by any formal channel. A confidential internal reporting mechanism, protected under applicable law, gives employees a safe path to escalate security concerns before they become public crises. This is also a regulatory expectation under both UK and Nigerian frameworks.	Both	Board/HR / Legal	Medium